RSI Group 內部 IT 數位賦能與轉型課程

第 11 堂

資安與維運韌性

不是不出事，而是出事時知道誰處理、多快恢復、資料不遺失

RSI Reliable Source Industrial

模組四　AI 應用、資安與推廣交接 ｜ 2027/01/18（一） ｜ 120 分鐘



Howard Liao Ph.D.

蜂巢計畫執行負責人・外部企業架構顧問

計劃主持人：周文津 副總經理

本堂學習目標

1

補齊基本防線

能檢核身分、權限、金鑰與 API 安全的基本要求。

2

設計備份與韌性

理解 3-2-1 備份原則與海外廠離線自治的設計要點。

3

建立事件處理

能依 P1 ～ P4 分級處理事件，並規劃一次桌上演練。

120 分鐘議程

0–10 分	回顧與開場	AI 應用卡
10–40 分	Part 1　身分、權限與 API 安全	基本防線
40–65 分	Part 2　備份、韌性與事件分級	3-2-1 、離線自治、 P1 ～ P4
65–75 分	中場休息	
75–112 分	Part 3　演練：桌上演練	情境推演
112–120 分	總結與作業	準備成果發表

上堂回顧與本堂銜接

1 上堂重點



AI 應用場景、人機協同簽核點、資料去識別化與決策軌跡。

2 本堂銜接



平台與 AI 越多，攻擊面越大，維運韌性越重要。

3 本堂產出



基本防線檢核表、事件分級表、一次桌上演練紀錄。

課前暖身：三個問題

Q1 你的管理帳號都有 MFA 嗎?

Q2 你上一次真的還原備份是什麼時候?

Q3 半夜系統出事，你知道該叫誰嗎?

課程地圖：十二堂在哪裡

第 1 堂
11/02 （一）
蜂巢計畫與 RSI 數位轉型總覽

第 2 堂
11/09 （一）
現況盤點與技術職能盤點

第 3 堂
11/16 （一）
IT 組織分工與權責

第 4 堂
11/23 （一）
成衣業務流程、資料與 KPI

第 5 堂
11/30 （一）
API Platform 與 API 管理

第 6 堂
12/07 （一）
Data Lake 與資料治理

第 7 堂
12/14 （一）
平台選型、TCO 與雲地配置

第 8 堂
12/21 （一）
版控收斂與技術棧體檢

第 9 堂
01/04 （一）
AI Coding 生命週期管理

第 10 堂
01/11 （一）
生成式 AI 應用與治理

第 11 堂
01/18 （一）
資安與維運韌性

第 12 堂
01/25 （一）
試點推廣、維運交接與成果發表

本堂在蜂巢計畫的位置



每一堂課的產出，直接成為蜂巢計畫該階段的交付輸入

本堂會帶走的產出



演練情境：週一清晨的勒索事件

一份事件處理時間軸與待改善清單



課後作業

完成團隊負責系統的基本防線檢核



課後作業

針對一個關鍵系統完成還原測試並記錄時間



課後作業

準備第 12 堂成果發表：團隊十二堂的產出彙整

上堂作業檢視：第 10 堂

作業	完成狀態	遇到的問題
完成並修訂團隊 AI 應用卡	☐ 完成 ☐ 進行中	
列出應用卡需要的資料，對照 Data Lake 範圍	☐ 完成 ☐ 進行中	
盤點團隊負責系統的帳號、權限與備份現況	☐ 完成 ☐ 進行中	

本堂學習路徑

補齊基本防線

能檢核身分、權限、金鑰與 API 安全的基本要求。

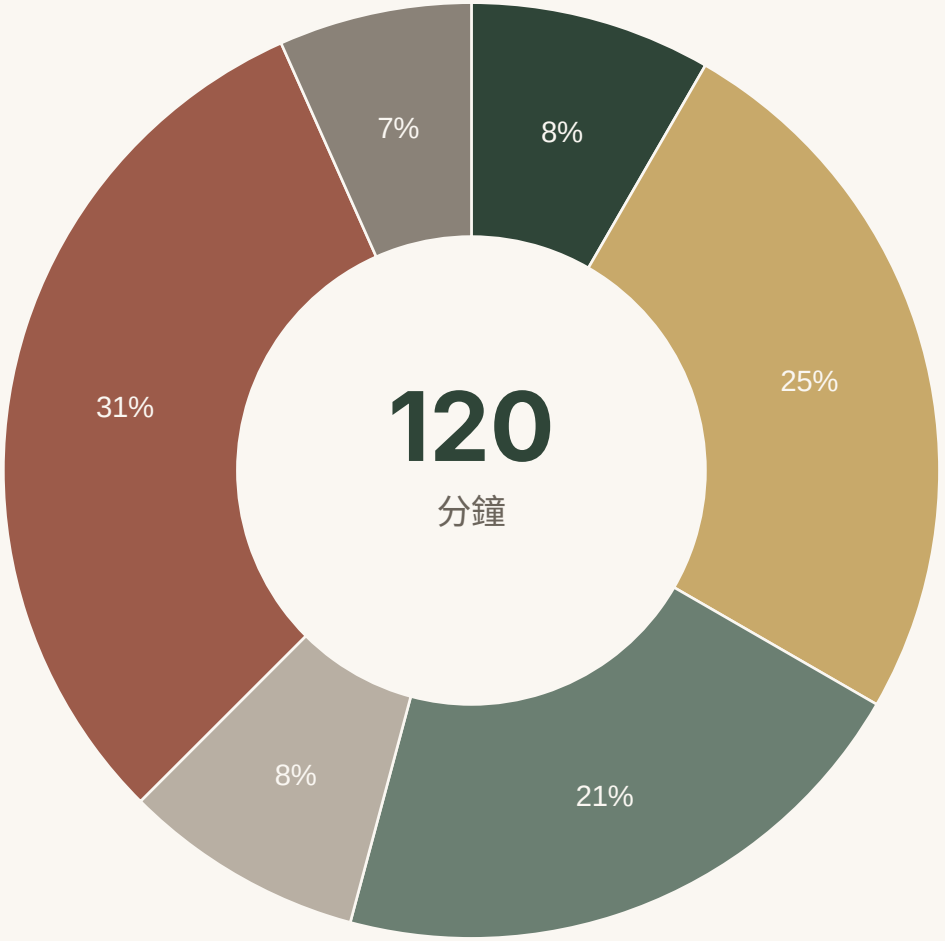
設計備份與韌性

理解 3-2-1 備份原則與海外廠離線自治的設計要點。

建立事件處理

能依 P1 ～ P4 分級處理事件，並規劃一次桌上演練。

120 分鐘怎麼用



回顧與開場	10 分
身分、權限與 API 安全	30 分
備份、韌性與事件分級	25 分
中場休息	10 分
演練：桌上演練	37 分
總結與作業	8 分

PART 01

身分、權限與 API 安全

多數事件，從一組帳號或一把金鑰開始。



本段導覽：身分、權限與 API 安全

01

基本防線檢核

02

API 安全的三道防護

03

AI Coding 帶來的新風險

基本防線檢核

項目	要求
多因子認證	管理帳號、遠端存取與雲端主控台全面啟用 MFA
最小權限	依角色與廠區授權，定期覆核並移除離職與異動帳號
金鑰管理	程式中不得寫死密碼與金鑰，統一由金鑰庫管理
特權帳號	共用管理帳號改為具名帳號，操作留下紀錄
弱點修補	定期掃描，高風險弱點限期修補

API 安全的三道防護

邊界	閘道統一入口、限流、 WAF 與異常流量阻擋
身分	每個呼叫端有自己的身分與權限範圍
行為	偵測合法身分的異常操作，如改參數撈取他人資料
開發	上線前自動執行 API 安全測試與 Secret 掃描

AI Coding 帶來的新風險

1 金鑰外洩

AI 產生的範例程式常把金鑰寫在程式中。

2 過時套件

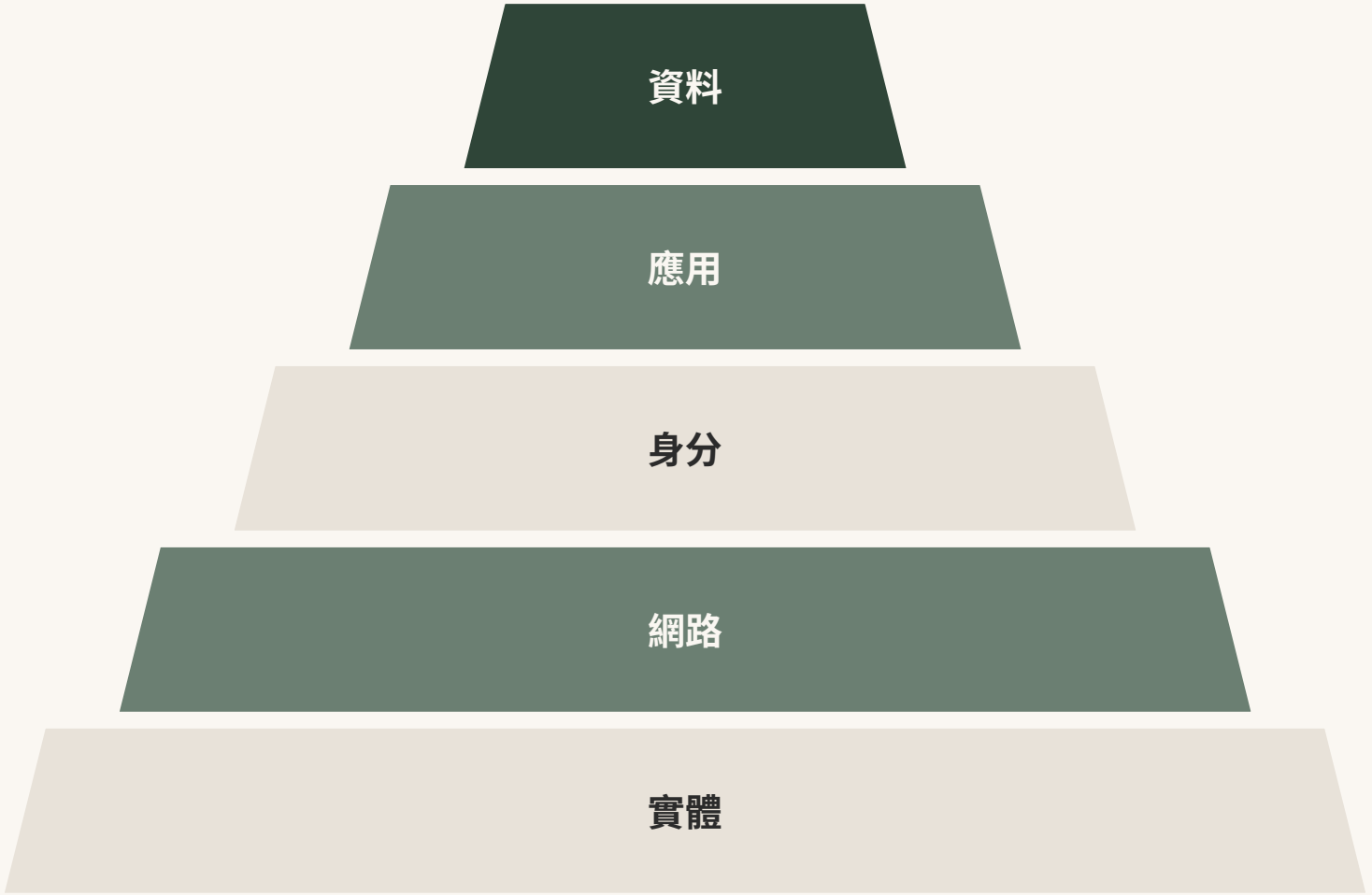
AI 可能引用有已知弱點的套件版本。

3 權限檢查遺漏

生成的 API 常忘了檢查呼叫者能不能存取該筆資料。

對策： Secret 掃描、 SCA 、權限相關變更列為高風險雙人審核

縱深防禦的層次



加密、備份、權限

安全開發與 API 防護

MFA 與最小權限

分段、閘道、 SD-WAN

機房與工廠設備

帳號生命週期

到職



依角色開通權限

異動



調整權限、移除舊權限

覆核



定期檢視權限

離職



當日停用帳號

段落小結：身分、權限與 API 安全



基本防線

MFA 、最小權限、金鑰管理、 API 安全。

本段走過的主題

- 基本防線檢核
- API 安全的三道防護
- AI Coding 帶來的新風險

PART 02

備份、韌性與事件分級



韌性要在平時設計，出事時才用得上。

本段導覽：備份、韌性與事件分級

01



3-2-1 備份原則

02



海外廠的離線自治

03



事件分級（P1～P4）

04



Help Desk 與值班

3-2-1 備份原則

1 3 份



正式資料加上兩份備份。

2 2 種媒體



存放在兩種不同的儲存媒體。

3 1 份異地



至少一份放在異地或離線，防範勒索軟體。

備份不等於可還原：定期做還原測試，才知道備份是否真的可用

海外廠的離線自治

斷線期間

- 邊緣節點維持產前門禁與推論比對
- 生產資料在本地暫存
- 關鍵功能 48 ～ 72 小時不中斷

恢復之後

- 自動補傳暫存資料
- 防止重複寫入
- 補傳完成後執行對帳

事件分級（P1～P4）

等級	影響	回應方式
P1	生產中斷或核心系統全面停擺	立即通報、全員動員、持續更新
P2	單廠或單一核心功能受影響	優先處理，定時回報進度
P3	部分使用者受影響，有替代方式	依排程處理
P4	一般問題或需求	列入待辦，依序處理

Help Desk 與值班

- 單一服務入口，所有問題先登錄再分派
- 每個系統都有主責與代理，休假時有人接手
- 各廠 IT 負責第一線，總部負責第二線支援
- 事件結束後檢討根因，並更新維運手冊

原則

工作要分清主責與副責；主責休假時，由代理人接手。

事件處理的六個步驟

01



偵測

監控與通報

02



分級

判定 P1 ～ P4

03



圍堵

隔離受影響範圍

04



根除

移除原因

05



復原

還原服務與資料

06



檢討

根因與改善

3-2-1 備份一眼看懂

3

份資料

正式資料加兩份備份

2

種媒體

不同儲存媒體

1

份異地

異地或離線保存

定期還原測試，才能確認備份可用

韌性設計的四個問題



誰處理

主責、代理與值班名單



多快恢復

依等級的回應與恢復時限



資料會不會遺失

備份頻率與還原測試



斷線怎麼辦

工廠離線自治與補傳

段落小結：備份、韌性與事件分級



可還原的備份

3-2-1 加上定期還原測試，海外廠能離線自治。

本段走過的主題

- 3-2-1 備份原則
- 海外廠的離線自治
- 事件分級（P1～P4）
- Help Desk 與值班

中場休息　10 分鐘

休息回來：演練：桌上演練

PART 03

演練：桌上演練

在會議室裡先把事故走一遍。



演練導覽：演練：桌上演練

01



演練情境：週一清晨的勒索事件

02



韌性檢核清單

演練情境：週一清晨的勒索事件

演練

20 分

跨團隊混合分組，指定指揮官、技術、溝通三種角色

產出

一份事件處理時間軸與待改善清單

1. 清晨發現某廠檔案伺服器被加密
2. 判定事件等級，決定通報對象
3. 決定隔離範圍與是否停止同步
4. 確認備份是否可用、還原順序
5. 列出事後要改善的三件事

演練情境：週一清晨的勒索事件：進行方式

步驟 1



清晨發現某廠檔案伺服器被加密

步驟 2



判定事件等級，決定通報對象

步驟 3



決定隔離範圍與是否停止同步

步驟 4



確認備份是否可用、還原順序

步驟 5



列出事後要改善的三件事

產出：一份事件處理時間軸與待改善清單

演練檢討

Q1 第一個 15 分鐘，誰做了什麼決定?

Q2 哪一項資訊最難拿到?

Q3 我們的備份，真的還原得回來嗎?

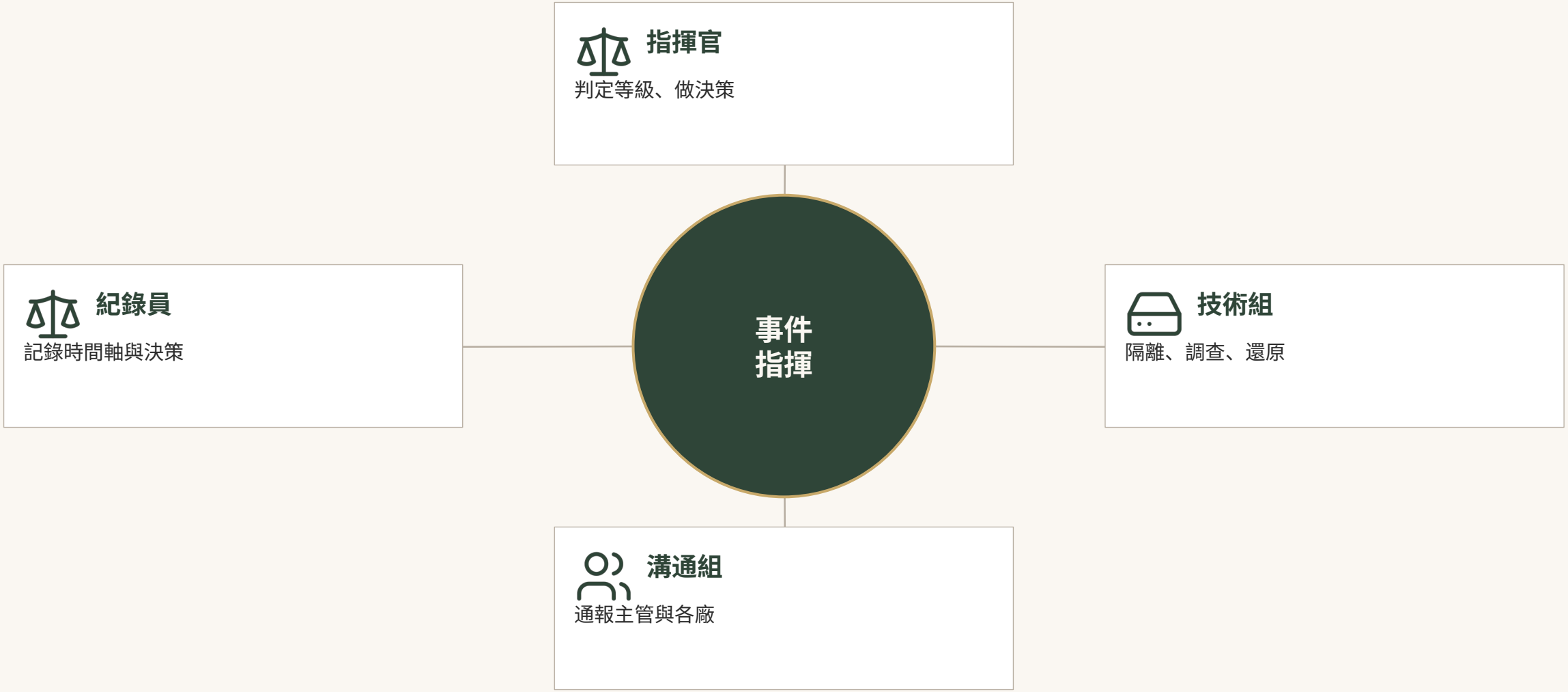
韌性檢核清單

- 所有管理帳號已啟用 MFA
- 程式中沒有寫死的密碼與金鑰
- 關鍵系統完成一次還原測試
- 海外廠斷線情境已演練
- 事件分級與通報名單已更新

下一步

未完成的項目列入維運交接清單，第 12 堂一併檢視。

桌上演練的角色分工



事件發生後第一個小時

0–15 分



確認事件並判定等級

15–30 分



通報與隔離範圍

30–45 分



確認備份與還原順序

45–60 分



對內說明與下一步

段落小結：演練：桌上演練



事件有分級

P1 ～ P4 、主責與代理、事後檢討。

本段走過的主題

- 演練情境：週一清晨的勒索事件
- 韌性檢核清單

本堂關鍵詞彙

詞彙	說明
MFA	多因子認證，密碼之外再加一層驗證
3-2-1 備份	3 份資料、 2 種媒體、 1 份異地或離線
P1 ～ P4	依影響範圍分級的事件等級
桌上演練	在會議室以情境推演事件處理流程
金鑰庫	集中管理密碼與金鑰，不寫在程式中

常見迷思與實際

迷思

- 有備份就安全
- 資安是 ITS 的事
- 小廠不會被攻擊

實際

- 還原得回來才算備份
- 每個開發者都要守金鑰與權限
- 攻擊常從最弱的一點進來

課後自我檢核

- ☐ 我負責的系統完成基本防線檢核
- ☐ 我完成一次還原測試並記錄時間
- ☐ 我知道 P1～P4 的回應方式
- ☐ 我參加了桌上演練並提出改善

未勾選的項目

列入本週待辦，並在下堂開場時回報進度。全部勾選者，可擔任下堂的同儕審查員。

關鍵詞彙圖解

MFA

多因子認證，密碼之外再加一層驗證

3-2-1 備份

3 份資料、 2 種媒體、 1 份異地或離線

P1～P4

依影響範圍分級的事件等級

桌上演練

在會議室以情境推演事件處理流程

金鑰庫

集中管理密碼與金鑰，不寫在程式中

行動承諾卡：下週一要做的一件事

我要做的事	對應本堂哪個重點	需要誰協助	完成日期

本堂重點回顧

1 基本防線

MFA 、最小權限、金鑰管理、API 安全。

2 可還原的備份

3-2-1 加上定期還原測試，海外廠能離線自治。

3 事件有分級

P1 ～ P4 、主責與代理、事後檢討。

課後作業與下堂預告

課後作業

- 完成團隊負責系統的基本防線檢核
- 針對一個關鍵系統完成還原測試並記錄時間
- 準備第 12 堂成果發表：團隊十二堂的產出彙整

下堂預告

第 12 堂：試點推廣、維運交接與成果發表

試點廠打樣、誰開發誰負責、維運手冊與 SLA ，以及結業發表。

給主管的一頁摘要

本堂結論

- 基本防線： MFA 、最小權限、金鑰管理、 API 安全。
- 可還原的備份： 3-2-1 加上定期還原測試，海外廠能離線自治。
- 事件有分級： P1 ～ P4 、主責與代理、事後檢討。

需要主管支持

- 完成團隊負責系統的基本防線檢核
- 針對一個關鍵系統完成還原測試並記錄時間
- 準備第 12 堂成果發表：團隊十二堂的產出彙整

從這一堂到下一堂

第 11 堂（本堂）

資安與維運韌性

產出：基本防線、可還原的備份、事件有分級

第 12 堂（下一堂）

試點推廣、維運交接與成果發表

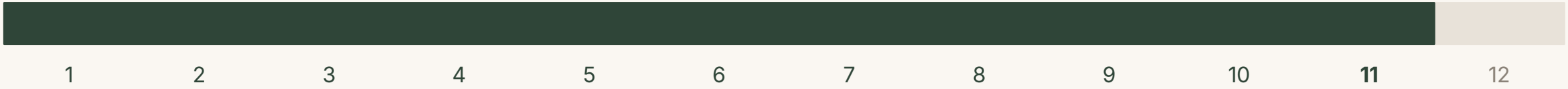
試點廠打樣、各廠承接、誰開發誰負責

本堂作業完成後，就是下一堂的起點

課程進度

92%

已完成 11 / 12 堂 ｜ 2026/11/02（一）至 2027/01/29（五）｜ 12 週／17 服務日



模組一

現況盤點與組織共識

第 1–3 堂

模組二

業務流程與資料底座

第 4–6 堂

模組三

平台選型與工程治理

第 7–9 堂

模組四

AI 應用、資安與推廣交接

第 10–12 堂

韌性不是不出事，
而是出事時不慌。

Howard Liao Ph.D. | 第 11 堂　資安與維運韌性